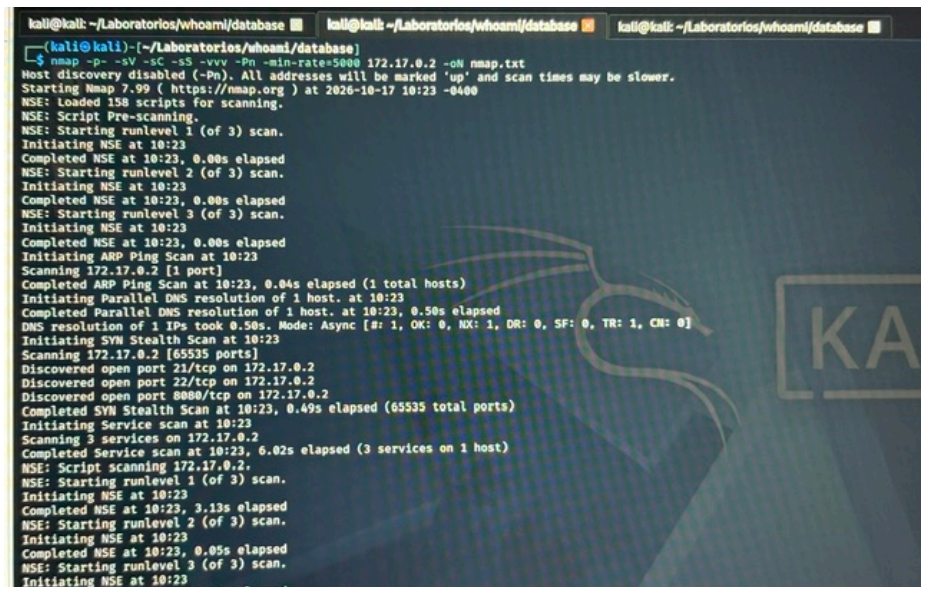
Writeup - Whoami-Labs

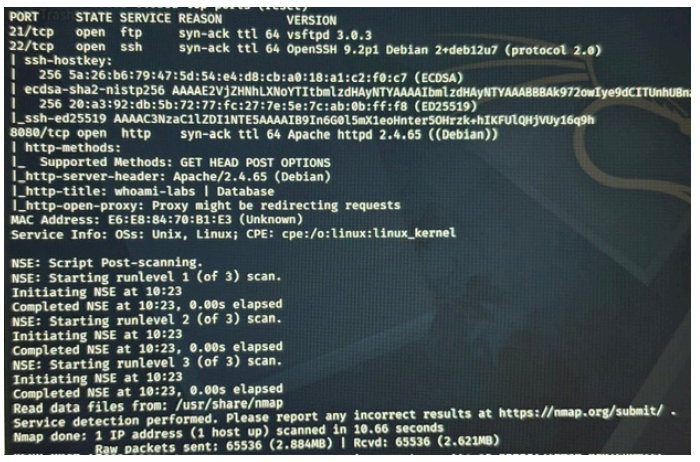
Laboratorio: Database

1.Información del laboratorio

Campo	Valor
Plataforma	whoami-labs.com
Laboratorio	Database
IP interna del objetivo	172.17.0.2
Atacante	Kali Linux
Servicios expuestos	FTP (21), SSH (22), HTTP (8080)

2.Reconocimiento (Nmap)





Escaneo completo de puertos y servicios:

nmap -p- -sV -sC -sS -vvv -Pn --min-rate=5000 172.17.0.2 -oN nmap.txt

Explicación de parámetros

- **-p-** : Escaneo de los 65535 puertos TCP
- **-sV** : Deteción de versiones.
- **-sC** : Scripts básicos NSE
- **-sS** : SYN Scan.
- **-Pn :** Omitir el descubrimiento inicial del host.
- **--min-rate=5000:** Aumenta la velocidad del escaneo.
- **-oN regla.txt** : Guarda la salida.

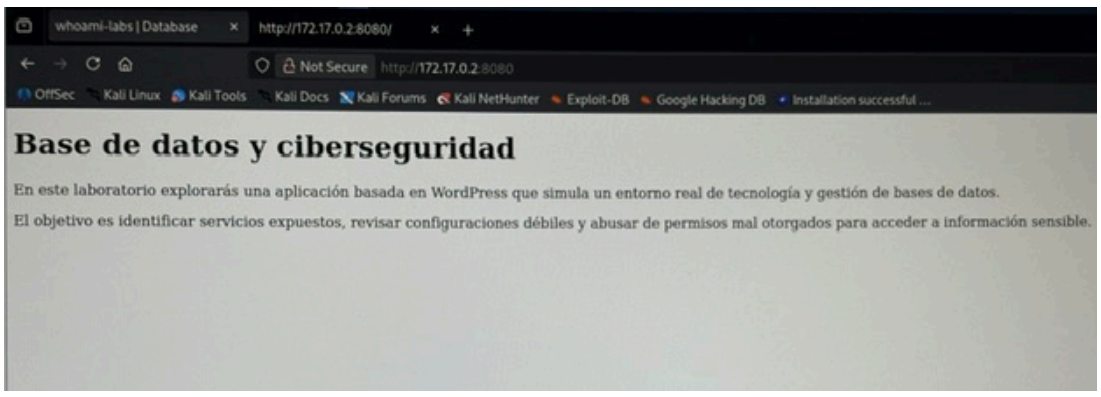
Resultado:

Puerto	Estado	Servicio	Versión
21/tcp	open	ftp	vsftpd 3.0.3
22/tcp	open	ssh	OpenSSH 9.2p1 (Debian)
8080/tcp	open	http	Apache httpd 2.4.65 (Debian)

El título de la página era “ whoami-labs | Database”, orientando la vía de ataque hacia la aplicación web.

3.Enumeración web

Al visitar http://172.17.0.2:8080/ se mostraba una página estática



Revisando el codigo fuente **(view-source)** se encontró un comentario HTML dejado por error por el administador del sitio.

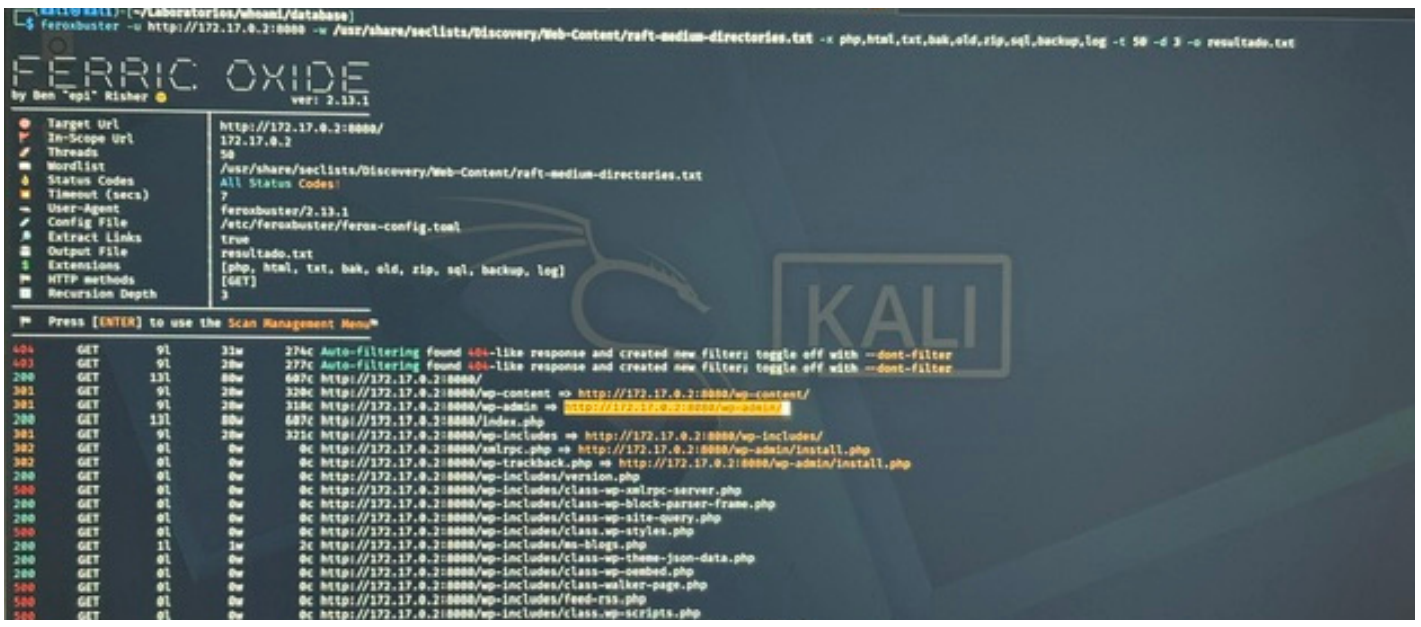


4.Enumeración de directorios (Feroxbuster)

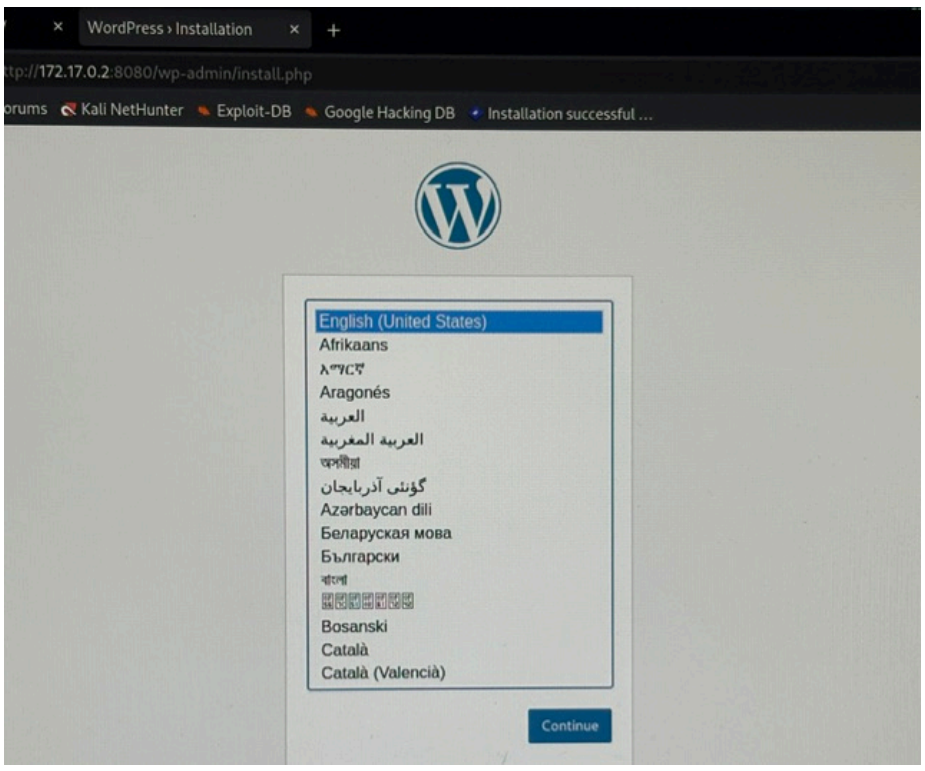
feroxbuster -u http://172.17.0.2:8080 -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -x php,html,bak,old,zip,sql,backup,log -t 50 -d 3 -o resultado.txt

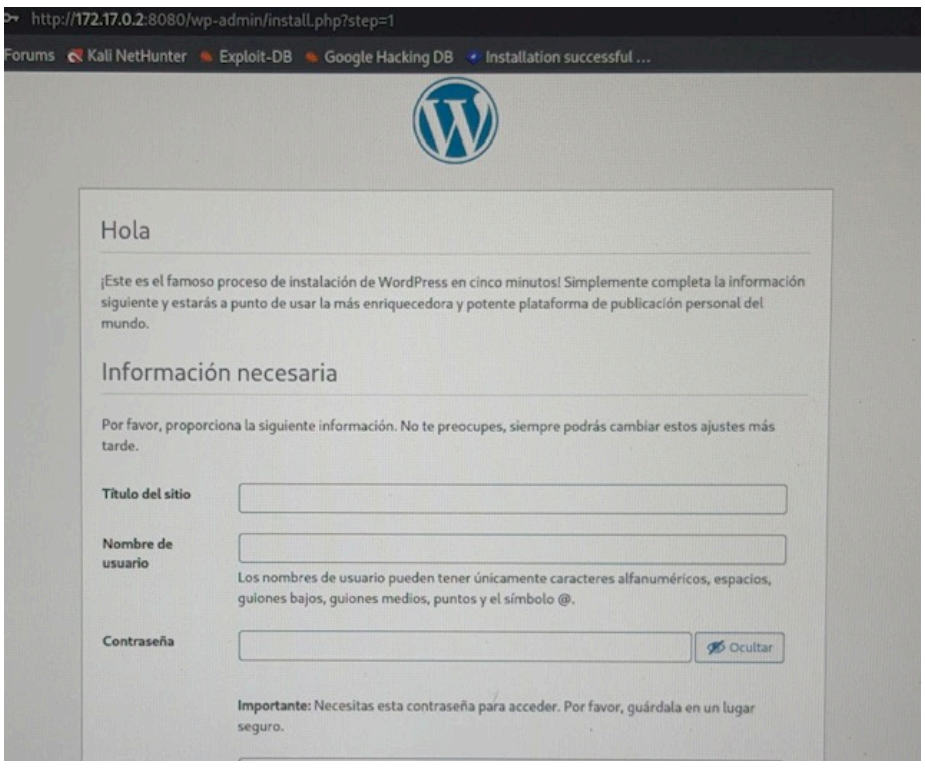
Explicación de los parametros:

- -u: URL objetivo
- -w: wordlist
- -x: extenciones a probar
- -t: hilos
- -d: profundidad de recursión
- -o: guardar la salida en un archivo



Se confirmó la estructura típica de WordPress (/wp-content/, /wp-admin/, /wp-includes/), y. clave para el ataque, que **/wp-admin/install.php** estaba accesible, es decir, WordPress aún no había sido instalado/configurado en el servidor.



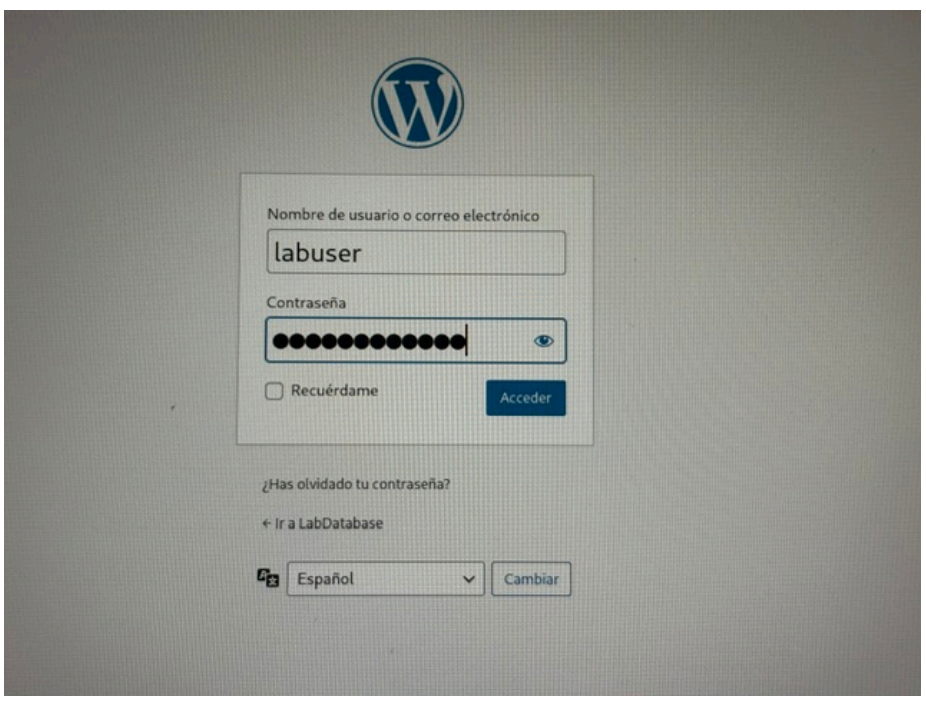


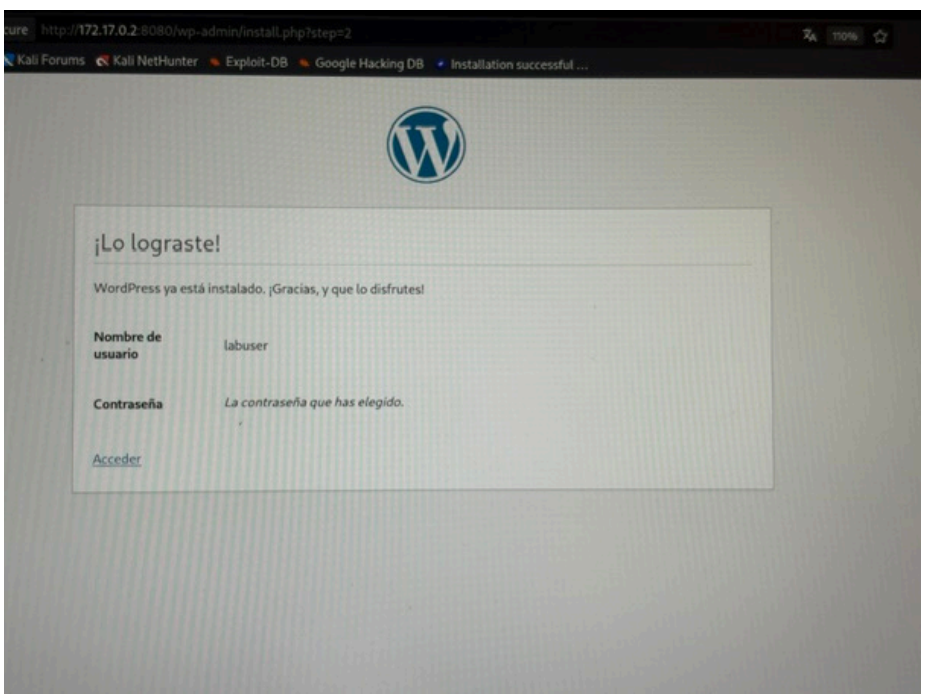
5.Instalación de WordPress

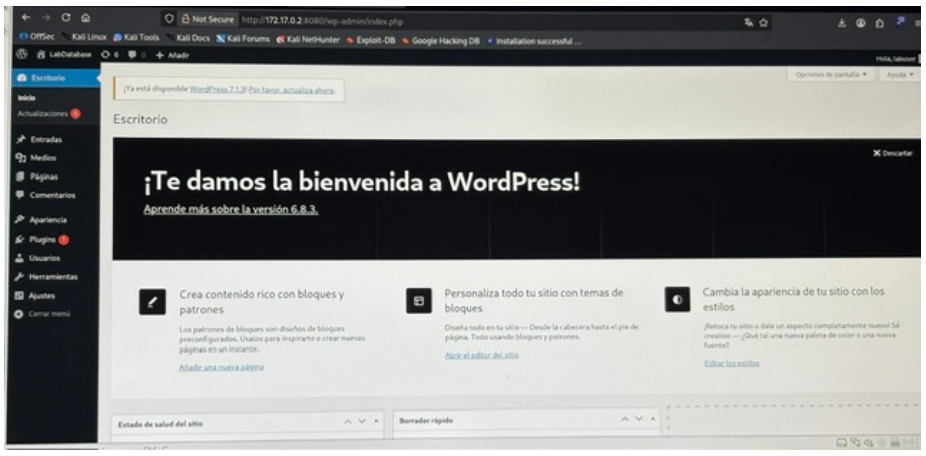
Al estar abierto el asistente de instalación, se completó como atacante, obteniendo así una cuenta de administrador legítima desde cero

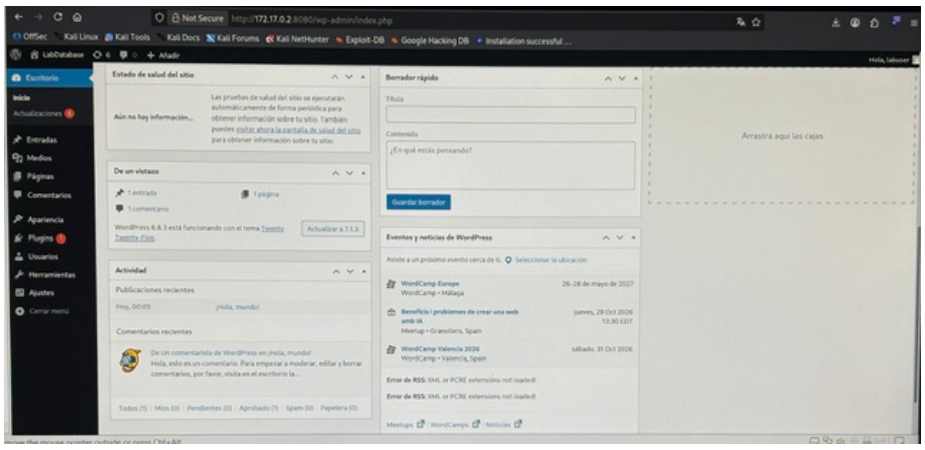
Campo	Valor
Título del sitio	LabDatabase
Usuario	labuser
Contraseña	.....
Correo	lab@test.local

Tras la instalación (“Lo lograste! WordPress ya está instalado”) sed accedió al panel en **http://172.17.0.2:8080/wp-admin/.**



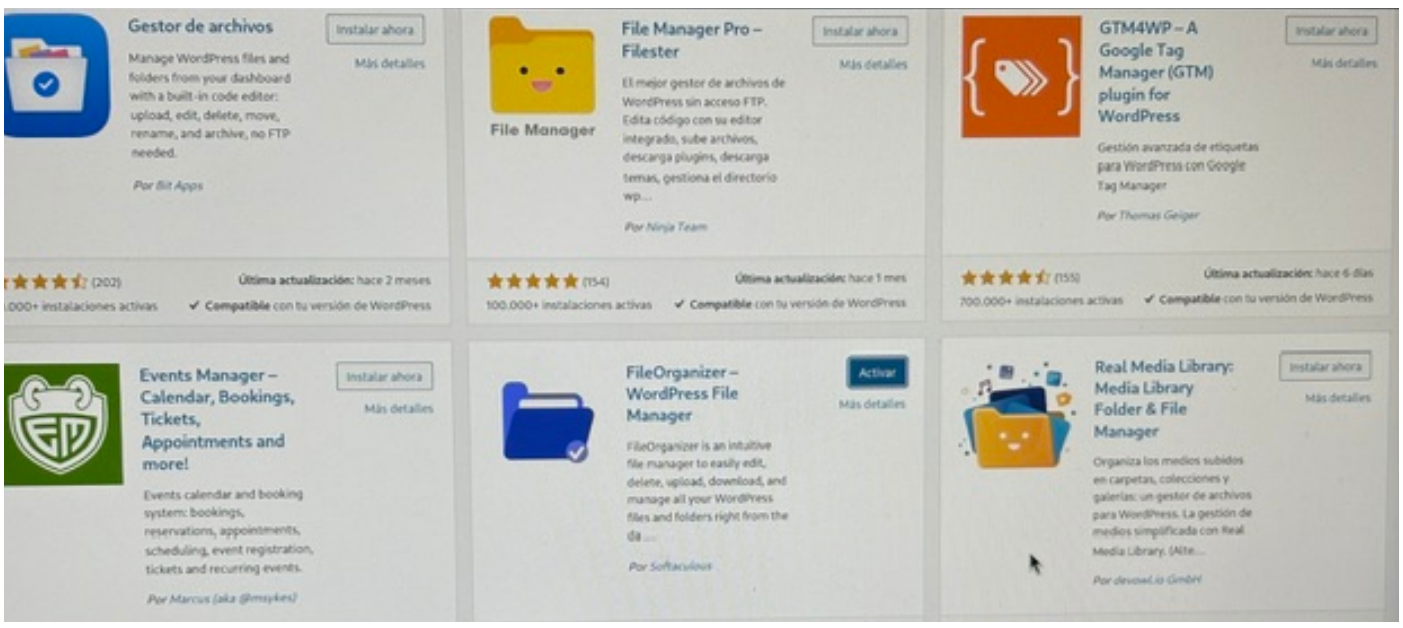




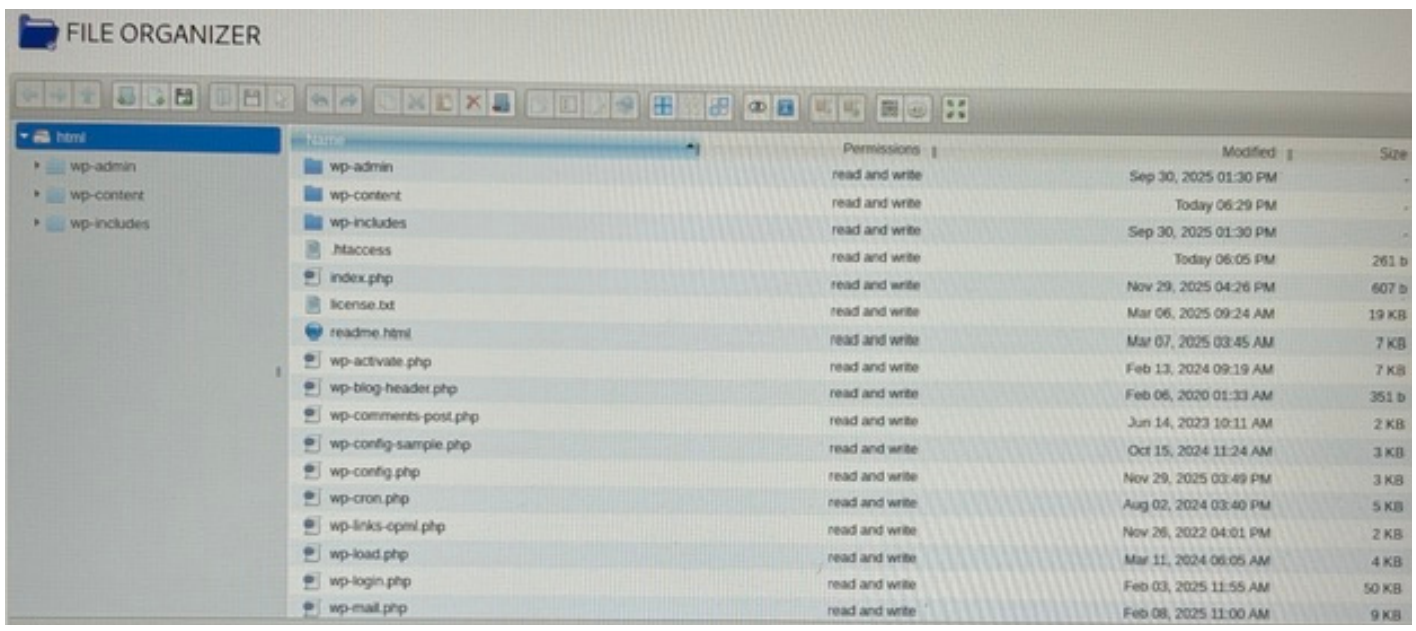


6.Obtención de ejecución remota de código (RCE)

Con acceso de administrador al panel, se aprovechó el editor de archivos de temas/plugins integrado en WordPress (wp-admin/theme-editor.php / plugin-editor.php), el cuál permite modificar directamente archivos PHP del sitio desde el navegador.

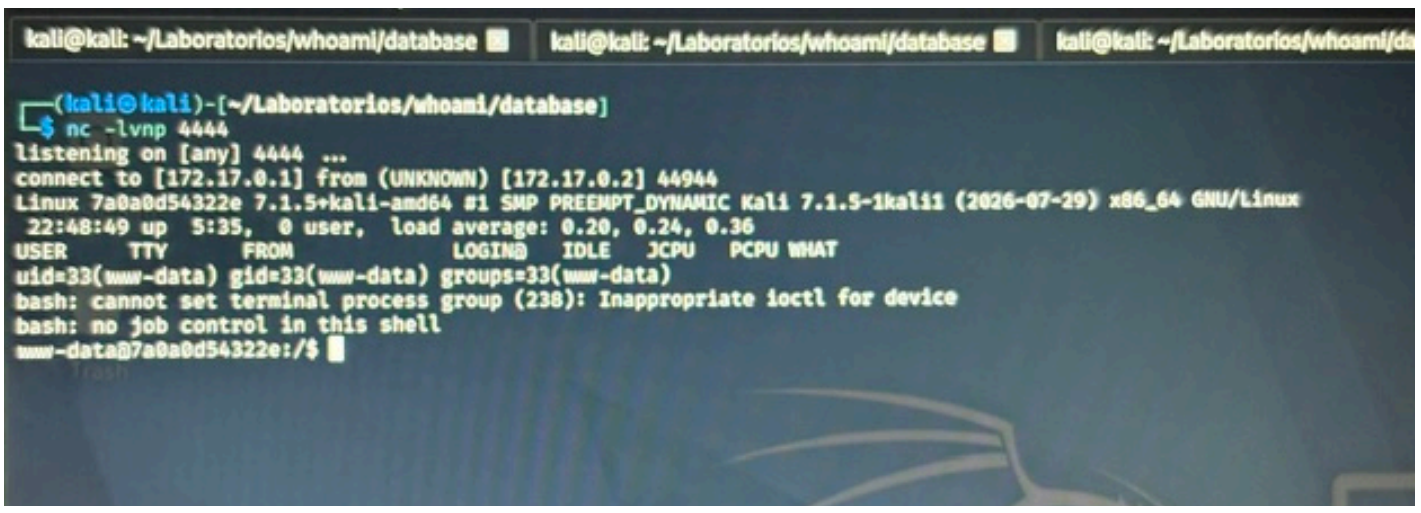


Se editó el archivo wp-mail.php (accesible públicamente sin autenticación) insertando un playload de reverse shell en PHP, y se guardó el cambio desde el editor.



7.Explotación - Reverse Shell

Listener en kali



Disparo del playload visitando el archivo modificado

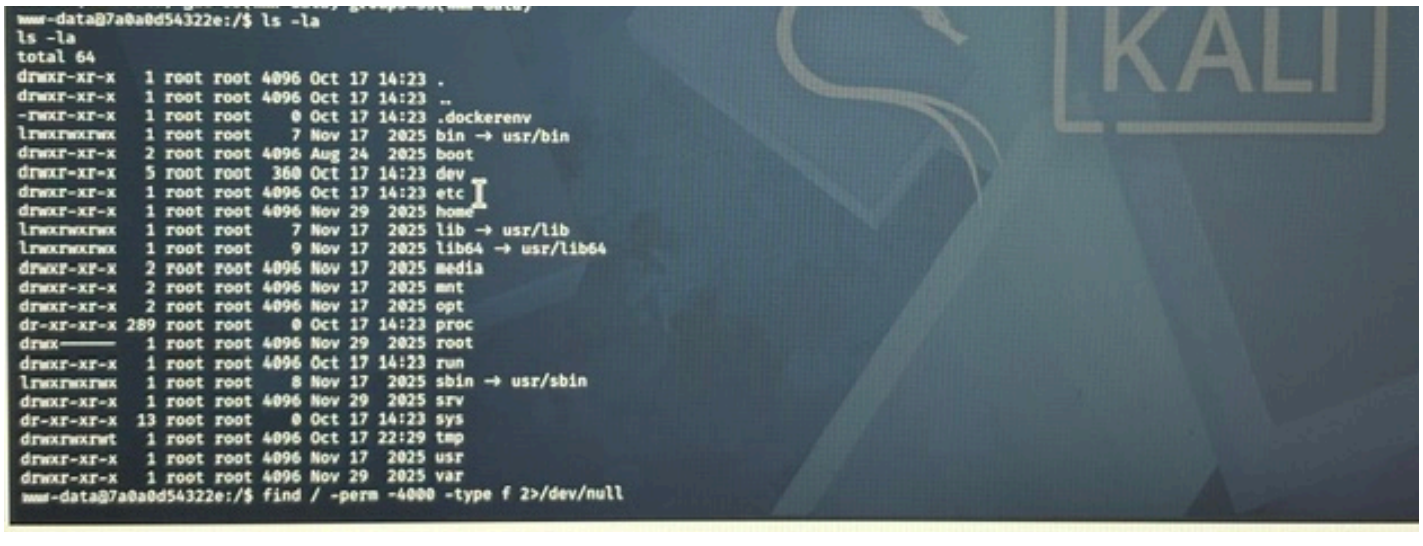
http://172.17.0.2:8080/wp-mail.php

Resultado:

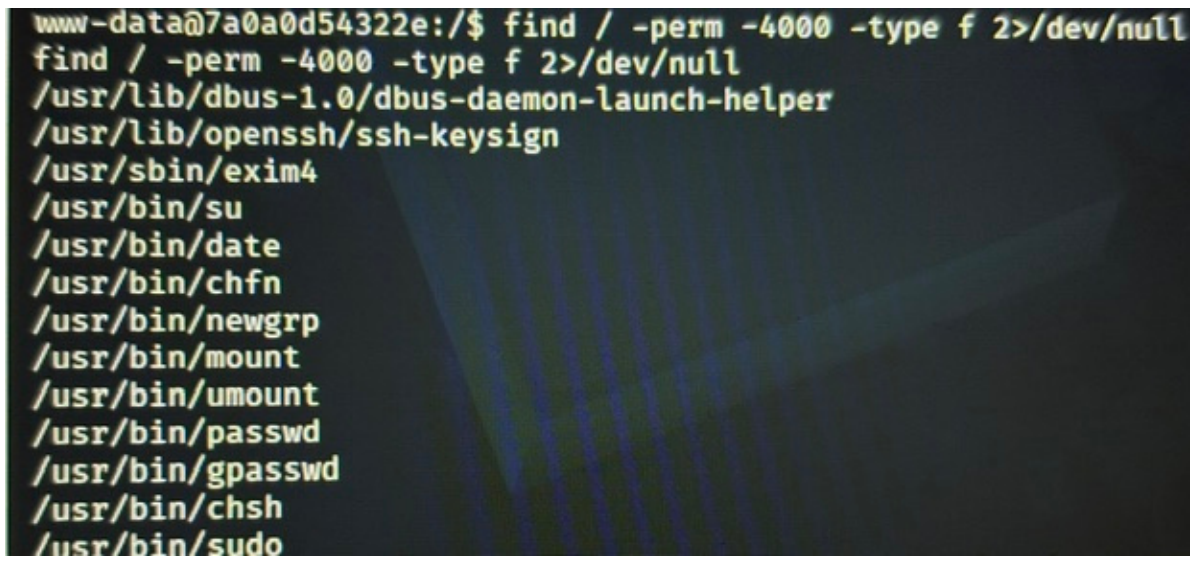


Shell obtenida como el usuario del servidor web **www.data**

8.Post-explotación -Enumeración del sistema



Busqueda de binarios con permisos SUID:



9.Escalación / Lectura de la flag (abuso del SUID en date)

Se identificó /usr/bin/date con el bit SUID activo. La opción -f de date permite indicarle un archivo cuyo contenido intentará intrepretar como fechas, líneas por líneas.

date -f /root/flag.txt

Por qué funciona: al tener el bit SUID, date se ejecuta con privilegios de root, independientemente del usuario que lo invoque (www.data). Esto le permite abrir y leer /root/flag.txt, un archivo al que www.data no tendría acceso por permisos normales. Como el contenido del archivo no es una fecha válida, date lo muestra en su mensaje de error al intentar pasearlo. filtrando así el contenido del archivo (flag).

10.Captura de la flag en la plataforma

